



FINAL YEAR PROJECT · PSM 1

SCHOOL OF COMPUTING (SECRH)

Design and Deployment of a Secure Cloud-Based Patient Data Management System Using a Three-Tier Architecture on AWS

Presented by	Mohamed Omar Makhlouf
Programme	BSc Computer Science (SECRH)
Supervisor	Mr. Johan Mohamed Sharif
Date	June 2026

Innovating Solutions



CHAPTER 1

Introduction

THE CLINIC

Alamin Clinic (Saudi Arabia) operated a fully manual, server-based patient records system with shared credentials, no access control, no encryption, and no backup policy.

THE INCIDENT

May 2023 — ransomware attack encrypted all patient data, halted operations for 5 days, caused permanent record loss, and made forensic investigation impossible.

THIS PROJECT PROPOSES

A secure, three-tier cloud-based patient data management system on AWS that eliminates the three structural gaps exposed by the ransomware attack — through layered RBAC, a full audit trail, and Terraform-driven recovery.

CHAPTER 1.2

Problem Statement

Three structural root-cause gaps identified from the Alamin Clinic ransomware case study:

P1**No Role-Based Access Control**

Shared credentials allowed any staff member to access any patient record regardless of role. No data isolation between doctors, admin, and patients.

HIGH IMPACT**P2****No Audit Trail**

No logging of who accessed or modified records. Post-incident forensic investigation was completely impossible.

HIGH IMPACT**P3****No Disaster Recovery**

No backup, no infrastructure-as-code, no documented recovery plan. Full recovery took 5 days with permanent data loss.

CRITICAL

Source: Stakeholder interviews + Alamin Clinic post-mortem analysis

Project Aim and Objectives

AIM

Design and deploy a secure, three-tier cloud-based patient data management system on AWS that directly eliminates all three critical gaps identified from the Alamin Clinic ransomware case study.

01

THREE-TIER VPC

Isolated Public, Private App, and Private DB subnets on AWS.

02

3-LAYER RBAC

JWT (app) · AWS IAM (infra) · PostgreSQL RLS (database)

03

DEVSECOPS PIPELINE

SonarQube SAST · Trivy image scan · Checkov IaC · gates block on failure

04

RTO < 15 MIN

Terraform IaC — full rebuild from clean state vs. 5-day recovery at Alamin Clinic.

CHAPTER 1.5

Project Scope

USER ROLES

Role	Permissions
Doctor	View and create medical records for assigned patients only
Admin	Register patients, manage appointments, manage users (no clinical data)
Patient	View own records and appointments — read-only

TECHNOLOGY STACK

AWS ap-southeast-1 · Node.js / Express · React (S3 + CloudFront) ·
Amazon RDS PostgreSQL · Terraform

PSM STAGES

PSM 1 — Analysis & Design · **PSM 2** — Implementation & Testing

OUT OF SCOPE

Mobile app · Payment processing · Third-party EHR integration

CHAPTER 2

Literature Review and Existing Systems

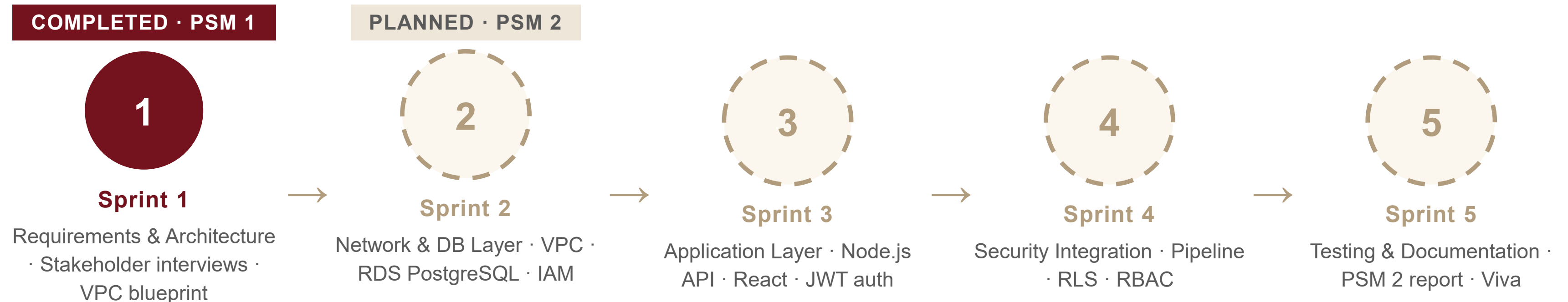
Three healthcare systems compared against the proposed system across five critical dimensions.

Feature	OpenEMR	Epic Systems	AWS Well-Arch.	Proposed
RBAC	Basic	Enterprise	None (app)	3-layer CloudTrail + DB Terraform RTO <15 min 6-stage automated ✓
Audit Trail	✗	✓	API only	
IaC / DR	✗	Proprietary	Partial	
DevSecOps Pipeline	✗	✗	✗	
Open-source / SME fit	✓	✗	Partial	

Research Gap — No existing system combines 3-layer RBAC + a full DevSecOps pipeline + Terraform-based RTO < 15 min in a single cloud-native deployment for Malaysian healthcare.

CHAPTER 3

Methodology



WHY AGILE + DEVSECOPS

Security requirements evolved iteratively through 2 stakeholder interviews · security gates automated at every sprint.

REQUIREMENTS (PSM 1)

12 Functional requirements · **11 Non-Functional** requirements · 2 stakeholder interviews

CHAPTER 4.3.1

System Architecture — Three-Tier AWS VPC

PUBLIC TIER

Application Load Balancer (HTTPS · port 443 only) NAT Gateway
(private subnet outbound)

PRIVATE APPLICATION TIER

EC2 — Node.js / Express REST API S3 + CloudFront — React static
frontend

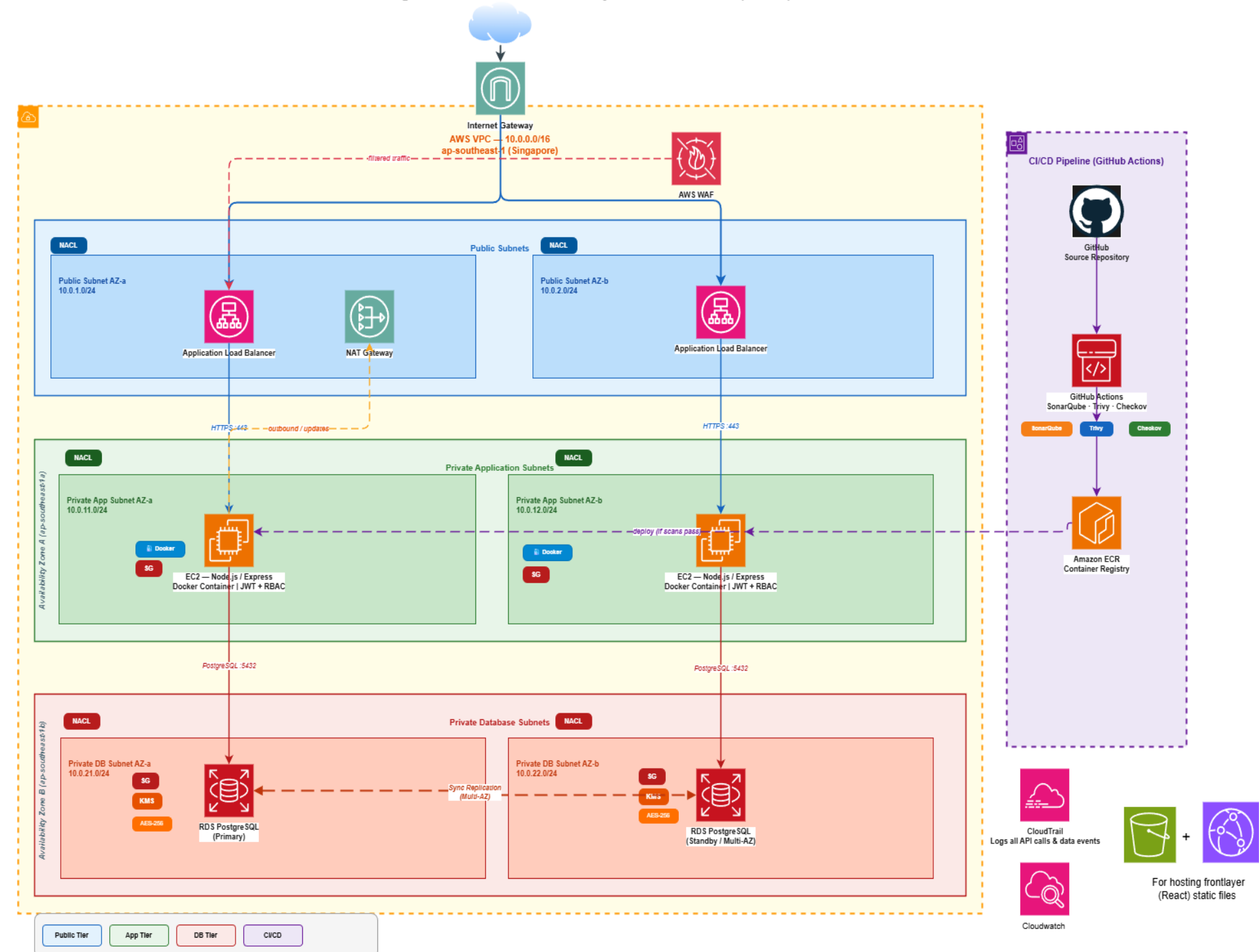
PRIVATE DATABASE TIER

Amazon RDS PostgreSQL · Multi-AZ AES-256 encryption at rest ·
RLS active

CROSS-CUTTING SECURITY

Security Groups · Network ACLs · IAM least-privilege · CloudTrail ·
Terraform IaC

Figure 4.2 — AWS Three-Tier System Architecture (PDMS)

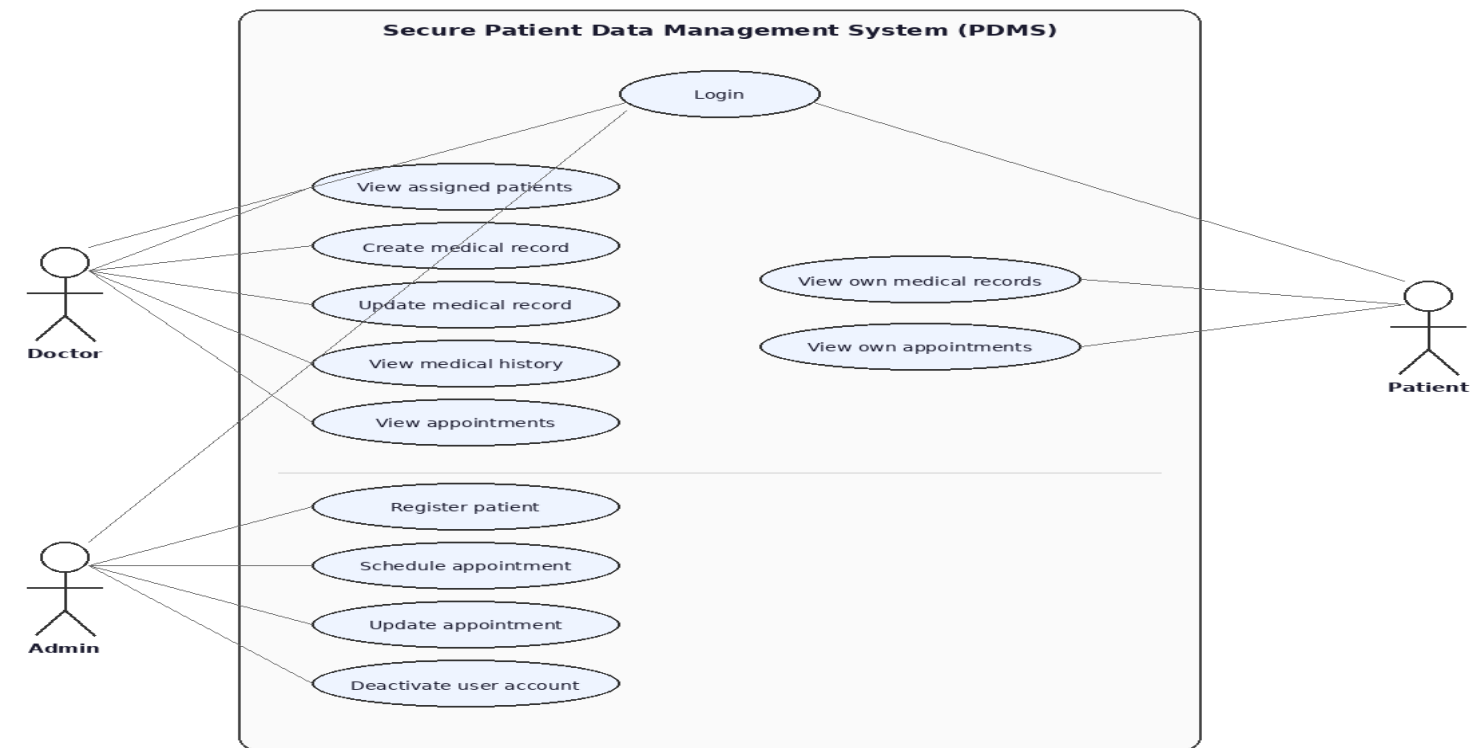


CHAPTER 4.3 – 4.4

System and Database Design

Use Case Diagram

3 actors · 18 use cases · 5 modules



USE CASE SUMMARY

- Doctor** View / create medical records (assigned patients only)
- Admin** Register patients · appointments · user management
- Patient** View own records and appointments (read-only)

DATABASE — 6 POSTGRESQL TABLES

users userId · UUID PK email · role passwordHash createdAt	patients patientId · UUID name · dob userId (FK) RLS active	doctors doctorId · UUID userId (FK) specialisation assignedPatients
medical_records recordId · UUID patientId · doctorId diagnosis · notes RLS enforced	appointments apptId · UUID patientId · doctorId datetime · status	audit_log logId · UUID userId · action table · timestamp INSERT ONLY

RLS rules — Doctors: own patients' records only · Patients: own profile only ·
 audit_log: no UPDATE or DELETE

Security Design and DevSecOps Pipeline

LAYER 1 — JWT (APP)

- httpOnly + Secure cookie
- bcrypt cost factor 12
- Role in token payload
- SameSite=Strict

LAYER 2 — AWS IAM (INFRA)

- Least-privilege per service
- EC2 cannot reach RDS directly
- S3 blocks public access
- Policies enforced by Terraform

LAYER 3 — POSTGRESQL RLS (DB)

- Doctors: assigned records only
- Patients: own profile only
- Independent of application code
- Bypass requires schema change

DEVSECOPS CI/CD PIPELINE — 6 STAGES

1 Code Checkout



2 SonarQube SAST
BLOCKS on CRITICAL



3 Docker Build



4 Trivy Image Scan
BLOCKS on CRITICAL
CVE



5 Checkov IaC Scan
BLOCKS on
HIGH/CRITICAL



6 Terraform Apply
ONLY if all 3 pass

HIPAA mapping: §164.312(a)(1) → 3-layer RBAC · §164.312(b) → CloudTrail + audit_log · §164.312(e)(2) → TLS + AES-256 · §164.312(a)(2)(ii) → Terraform RTO < 15 min

APPENDIX E

Interface Wireframes — Role-Based Design

Fig E.1 — Login

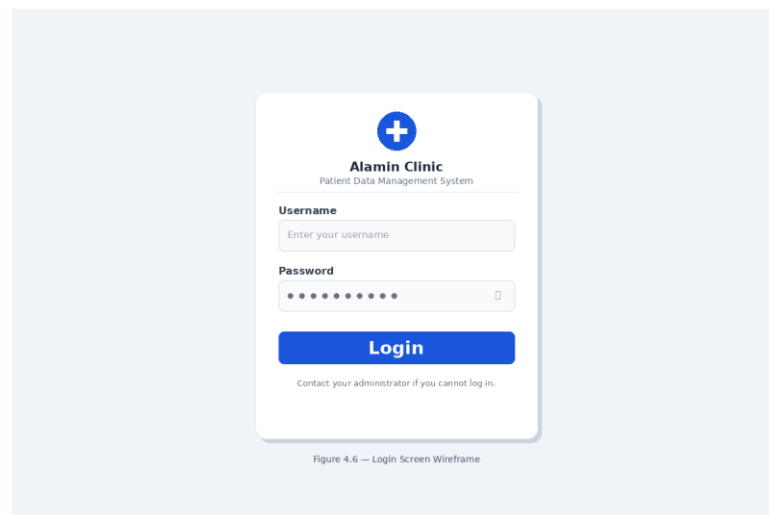


Fig E.2 — Doctor Dashboard

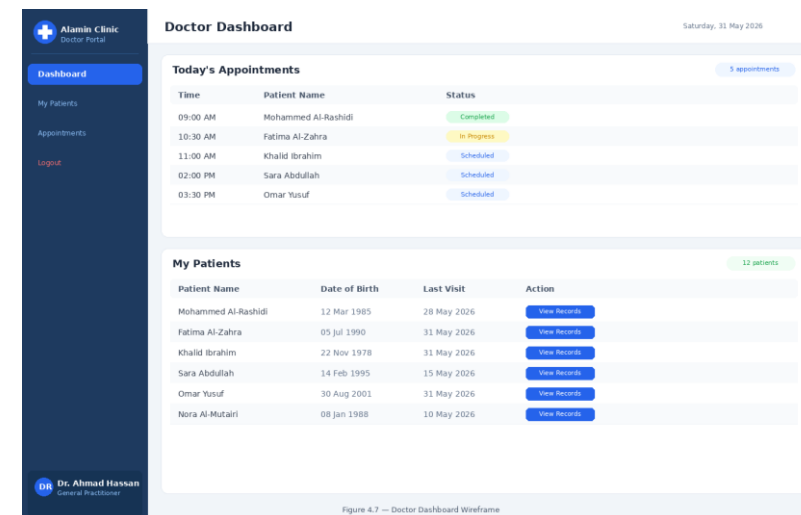


Fig E.3 — Admin Dashboard

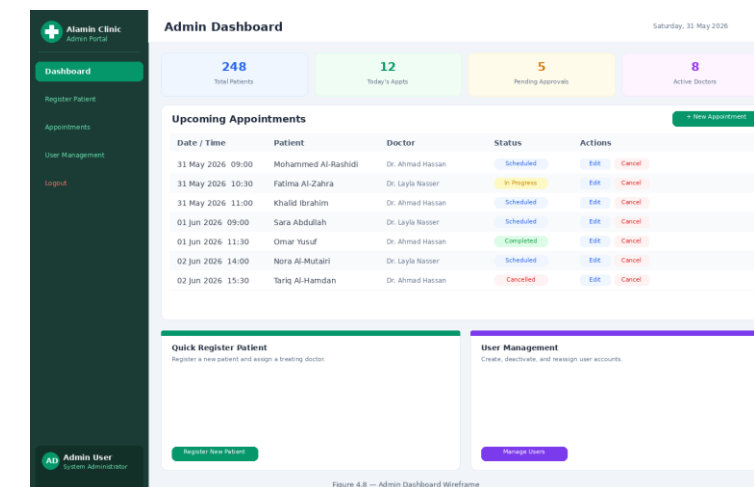
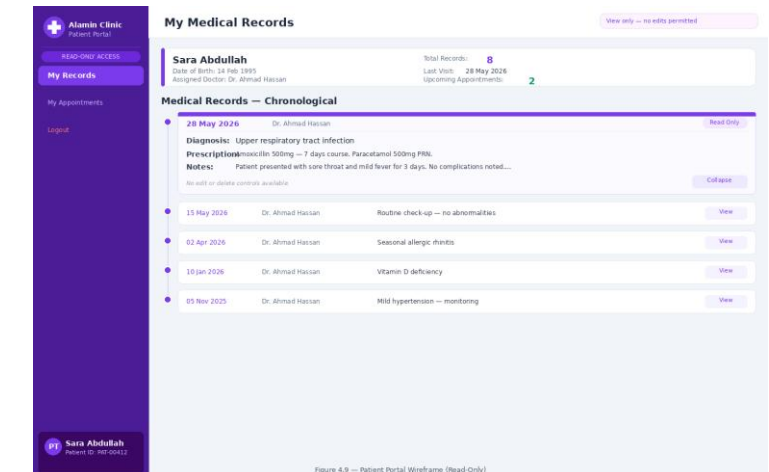


Fig E.4 — Patient Portal



- Single entry for all 3 roles
- JWT redirects to role dashboard
- No self-registration

- My Patients + Appointments
- New Record — assigned only
- No admin functions visible

- Register Patient · Appointments
- User Management
- No clinical data visible

- My Records (read-only)
- My Appointments
- No edit or delete controls

Key principle: role isolation is enforced visually — each screen surfaces only what that role is permitted to access.

CHAPTER 4.9

Evaluation Plan

01 Functional Testing	02 Security Testing	03 Pipeline Testing	04 Recovery Testing	05 Compliance Audit
Test cases for all 18 use cases · positive and negative scenarios · covers all 12 FRs	Penetration testing to validate 3-layer RBAC · confirm RLS cannot be bypassed from app layer	Confirm each security gate blocks on CRITICAL · confirm Terraform apply only runs on full pass	Destroy test environment → terraform apply → measure RTO · Target: < 15 minutes	HIPAA §164.312 compliance validation · Malaysia PDPA 2010 review

All evaluation activities planned for **PSM 2** — the system has not yet been implemented.

CHAPTER 5

PSM 1 Achievements and PSM 2 Plan

PSM 1 Completed

- ✓ Ransomware root cause analysis (Alamin Clinic)
- ✓ 2 stakeholder interviews conducted
- ✓ 18 use cases · 12 FR · 11 NFR
- ✓ Three-tier AWS VPC architecture designed
- ✓ 3-layer RBAC model defined (JWT + IAM + RLS)
- ✓ 6-stage DevSecOps pipeline designed
- ✓ Database schema + RLS policies (6 tables)
- ✓ 4 role-based wireframes (Appendix E)
- ✓ HIPAA §164.312 compliance mapping

PSM 2 Planned · June–November 2026

- VPC + RDS + IAM deployment via Terraform
- Node.js / Express backend + React frontend
- JWT authentication + PostgreSQL RLS activation
- DevSecOps pipeline activation and testing
- Penetration testing + formal security audit
- PDPA 2010 compliance review
- PSM 2 documentation + viva

QUESTIONS & DISCUSSION

Thank You.

Project	Secure Cloud-Based Patient Data Management System — Three-Tier Architecture on AWS
Presenter	Mohamed Omar Makhlouf
Supervisor	Mr. Johan Mohamed Sharif
Faculty	SECRH · Universiti Teknologi Malaysia, Johor Bahru